

SIMATS ENGINEERING
ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name:

COURSE OUTCOME COVERED

***CO5:** Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: Answer all questions. Each question carries 20 marks.

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Code of Conduct:

I M.NITHIYASHREE-192421101_ (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: M.NITHIYASHREE

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and constraints	Good understanding with minor gaps in requirements	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem context	

Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

Q1. Windows Domain Network – Attack Spread Analysis

Given Data

- Total systems = **150**
- Systems allowing anonymous enumeration = **45%**
- Among these, systems susceptible to SMB lateral movement = **60%**
- Each compromised system attempts to access **3 additional systems**
- Probability of successful access per attempt = **0.3**

Step 1: Initial systems compromised

First, calculate the number of systems allowing anonymous enumeration:

$$150 \times 45\% = 150 \times 0.45 = 67.5$$

Approximately **68 systems** allow anonymous enumeration.

Among these, 60% are susceptible to SMB-based lateral movement:

$$67.5 \times 60\% = 67.5 \times 0.60 = 40.5$$

Therefore, approximately:

$$41 \text{ systems}$$

can be considered initially compromised/susceptible through the identified weaknesses.

Step 2: Second-stage lateral movement

Each compromised system attempts to access **3 systems**.

Total attempts:

$$41 \times 3 = 123$$

With a success probability of **0.3**:

$$123 \times 0.3 = 36.9$$

Therefore, the expected number of newly compromised systems is approximately:

$$37 \text{ systems}$$

Step 3: Total expected compromise

Initial compromise:

4141

Second-stage compromise:

3737

Therefore:

$$41+37=78 \quad 41+37=78$$

Approximately **78 systems** could be compromised after two stages.

Percentage of the network:

$$78/150 \times 100 = 52\% \quad \frac{78}{150} \times 100 = 52\%$$

So the estimated compromise is:

$$52\% \quad \boxed{52\%}$$

Step 4: Is the network at risk of >70% compromise?

70% of 150 systems is:

$$150 \times 0.70 = 105 \quad 150 \times 0.70 = 105$$

The estimated number compromised is **78**, which is below **105**.

Therefore:

$$78 < 105 \quad \boxed{78 < 105}$$

Conclusion: Based strictly on the two-stage calculation given, the network **does not exceed the 70% large-scale compromise threshold**. However, the presence of substantial anonymous enumeration and lateral-movement exposure still represents a serious security risk because further attack stages could increase the number of compromised systems.

Step 5: Vulnerability to prioritize

The most immediate priority should be **NULL sessions / anonymous enumeration**.

Reason:

- 45% of the organization's systems permit anonymous enumeration.
- It provides attackers with information that can help identify users, systems, shares, and network resources.
- This information can facilitate subsequent SMB-based lateral movement.
- Reducing anonymous access can therefore disrupt the attack chain at an early stage.

The organization should also address **weak shared-folder permissions** and unnecessary **RPC exposure**, but anonymous/NULL-session access should be addressed first because it enables reconnaissance that can support later attacks.

Final Answer

The initial analysis indicates that approximately **41 systems** are exposed to SMB-based lateral movement. These systems can generate approximately **123 lateral-movement attempts**, of which about **37 attempts** are expected to succeed. Thus, approximately **78 of the 150 systems (52%)** may be compromised after two stages. Since 70% of the network corresponds to 105 systems, the estimated compromise remains below the large-scale compromise threshold. However, the network still has a significant security weakness because anonymous enumeration can provide attackers with information required for further lateral movement. Therefore, **NULL-session/anonymous enumeration should be prioritized for immediate mitigation**, followed by hardening RPC services and correcting shared-folder permissions.

Q2. RPC Exploitation – Expected Compromise and Detection

Given Data

- Total systems = **120**
- Systems exposing RPC = **70**
- Susceptible to known exploits = **40%**
- Probability of successful exploitation = **0.5**
- Detection probability per exploitation attempt = **0.25**

Step 1: Calculate vulnerable RPC systems

$$70 \times 40\% = 70 \times 0.4 = 28$$

Therefore, **28 systems** are vulnerable to known RPC exploits.

Step 2: Expected number of successfully compromised systems

The probability of successful exploitation is **0.5**.

$$28 \times 0.5 = 14$$

Therefore:

14 systems

are expected to be successfully compromised.

Step 3: Expected number of detection alerts

Each exploitation attempt has a detection probability of **0.25**.

There are **28 vulnerable systems**, so:

$$28 \times 0.25 = 7$$

Therefore, the expected number of detection alerts is:

7 alerts

Step 4: Evaluate the risk to a stealthy attacker

The attacker faces two important probabilities:

- Successful exploitation = **50%**
- Detection = **25%**

This means RPC exploitation has a reasonable chance of success, but it also creates a significant possibility of detection.

For 28 vulnerable systems:

$$28 \times 0.5 = 14$$

expected successful compromises, while:

$$28 \times 0.25 = 7$$

detection alerts may be generated.

Thus, an attacker trying to remain **stealthy** may avoid repeated direct RPC exploitation because multiple exploitation attempts can generate several IDS alerts. Instead, from a defensive

perspective, organizations should expect attackers to potentially seek **less detectable attack paths**, such as credential abuse, phishing, or exploitation of other exposed services.

Final Answer

Out of 70 systems exposing RPC services, **40% (28 systems)** are vulnerable to known exploits. With a successful exploitation probability of **0.5**, the expected number of successfully compromised systems is **14**. The detection probability is **0.25 per vulnerable exploitation attempt**, resulting in an expected **7 detection alerts**. Therefore, RPC exploitation provides a significant opportunity for compromise but also creates a considerable detection risk. An attacker prioritizing stealth may avoid repeated RPC exploitation and look for alternative attack paths with lower detection probability. From the organization's perspective, RPC services should be minimized, patched, restricted to trusted systems, and continuously monitored by IDS/IPS.

Q3. Cloud-Hosted Linux Server – Vulnerability and Full Compromise

Given Data

There are **4 critical internet-facing services** with independent vulnerability probabilities:

- Service 1 = **0.30**
 - Service 2 = **0.20**
 - Service 3 = **0.25**
 - Service 4 = **0.15**
 - Probability of privilege escalation through weak file permissions = **0.50**
-

Step 1: Probability that no service is vulnerable

For each service, the probability that it is **not vulnerable** is:

$$1 - P(V)$$

Therefore:

$$(1 - 0.30)(1 - 0.20)(1 - 0.25)(1 - 0.15)(1 - 0.30)(1 - 0.20)(1 - 0.25)(1 - 0.15) \\ = 0.70 \times 0.80 \times 0.75 \times 0.85 = 0.70 \times 0.80 \times 0.75 \times 0.85 = 0.357 = 0.357$$

So, the probability that **none of the services is vulnerable** is:

$$0.357 \boxed{0.357}$$

Step 2: Probability that at least one service is vulnerable

Use the complement rule:

$$P(\text{at least one vulnerable}) = 1 - P(\text{none vulnerable}) \\ P(\text{at least one vulnerable}) = 1 - P(\text{none vulnerable}) = 1 - 0.357 = 0.643 = \boxed{0.643}$$

Therefore:

$$64.3\% \boxed{64.3\%}$$

There is a **64.3% probability that at least one exposed service is vulnerable.**

Step 3: Probability of full system compromise

For full compromise, assume:

1. At least one service is vulnerable and provides initial access.
2. Weak file permissions then allow privilege escalation.

Therefore:

$$P(\text{full compromise}) = P(\text{service vulnerability}) \times P(\text{privilege escalation}) \\ P(\text{full compromise}) = P(\text{service vulnerability}) \times P(\text{privilege escalation}) = 0.643 \times 0.50 = 0.3215 = \boxed{0.3215}$$

Therefore:

$$32.15\% \boxed{32.15\%}$$

The estimated overall probability of full system compromise is **32.15%.**

Step 4: Evaluate strengthening file permissions alone

If file permissions are strengthened, the probability of privilege escalation can be greatly reduced.

However, the probability of obtaining **initial access remains 64.3%** because the four

internet-facing services are still exposed.

Therefore, securing file permissions **reduces the risk of full system compromise**, but it does **not eliminate the primary attack surface**.

The organization should also:

- Patch vulnerable services regularly.
- Disable unnecessary internet-facing services.
- Restrict access using firewalls/security groups.
- Apply least-privilege permissions.
- Monitor suspicious login and service activity.
- Use vulnerability scanning and intrusion detection.

Final Answer

The probability that none of the four services is vulnerable is **35.7%**. Therefore, the probability that at least one service is vulnerable is **64.3%**. Considering the **50% probability of privilege escalation through weak file permissions**, the overall probability of full system compromise is **32.15%**. Strengthening file permissions would reduce the possibility of privilege escalation and therefore lower the probability of complete compromise. However, it should not be the only mitigation because the server still has a **64.3% probability of having at least one vulnerable exposed service**. Therefore, service hardening, patching, network restriction, and permission management should all be implemented together.

4. NFS Unauthorized Access and Complete System Compromise

Given Data

- Number of internal subnets = **3**
 - Unauthorized access probability from:
 - Subnet 1 = **0.4**
 - Subnet 2 = **0.3**
 - Subnet 3 = **0.2**
 - Probability of privilege escalation to root after NFS access = **0.7**
-

Step 1: Probability that none of the subnets gains unauthorized access

The probability that each subnet **does not** gain unauthorized access is:

$$1-P(A)1-P(A)$$

Therefore:

$$(1-0.4)(1-0.3)(1-0.2)(1-0.4)(1-0.3)(1-0.2) = 0.6 \times 0.7 \times 0.8 = 0.6 \times 0.7 \times 0.8 = 0.336 = 0.336$$

So, the probability that **none of the subnets gains unauthorized access** is:

$$0.336 \boxed{0.336}$$

Step 2: Probability that at least one subnet gains unauthorized access

Using the complement rule:

$$\begin{aligned} P(\text{at least one access}) &= 1 - P(\text{none}) \\ P(\text{at least one access}) &= 1 - P(\text{none}) \\ &= 1 - 0.336 = 1 - 0.336 = 0.664 = \boxed{0.664} \end{aligned}$$

Therefore:

$$66.4\% \boxed{66.4\%}$$

There is a **66.4% probability** that at least one subnet successfully gains unauthorized access to the NFS share.

Step 3: Probability of complete system compromise

Once unauthorized NFS access is obtained, the probability of privilege escalation to root is **0.7**.

Therefore:

$$\begin{aligned} P(\text{complete compromise}) &= P(\text{unauthorized access}) \times P(\text{root escalation}) \\ P(\text{complete compromise}) &= P(\text{unauthorized access}) \times P(\text{root escalation}) \\ &= 0.664 \times 0.7 = 0.664 \times 0.7 = 0.4648 = 0.4648 \end{aligned}$$

Therefore:

$$46.48\% \boxed{46.48\%}$$

The overall probability of complete system compromise is **46.48%**.

Step 4: Evaluate restricting NFS to a single subnet

Restricting NFS access to only one trusted subnet can significantly reduce the attack surface.

For example, if only **Subnet 1** is permitted, the unauthorized-access probability would be:

$$P(A)=0.4$$

The resulting complete compromise probability would be:

$$0.4 \times 0.7 = 0.28 \quad 28\%$$

Compared with the original **46.48%**, this represents a significant reduction in risk.

However, simply restricting access to one subnet is **not sufficient by itself**. The permitted subnet should also use strong authentication, firewall rules, least-privilege access, secure NFS configuration, and monitoring.

Final Answer

The probability that none of the three subnets obtains unauthorized access to the NFS share is **33.6%**. Therefore, the probability that at least one subnet gains unauthorized access is **66.4%**. Considering the **70% probability of privilege escalation to root**, the overall probability of complete system compromise is **46.48%**. Restricting NFS access to a single trusted subnet would reduce the unauthorized-access probability to **40%** and the estimated complete compromise probability to **28%**. Hence, restricting NFS access is an effective mitigation strategy because it reduces the attack surface, but it should be combined with authentication, least privilege, firewall controls, and monitoring.

Q5. SQL Injection – Data Extraction and Breach Severity

Given Data

- Total user records = **50,000**
 - Sensitive records = **30%**
 - Data extraction rate = **500 records/second**
 - Firewall blocks attack after = **40 seconds**
-

Step 1: Calculate total records extracted

The attacker can extract **500 records per second** for **40 seconds**.

$$\text{Records extracted} = 500 \times 40 \quad \{\text{Records extracted}\} = 500 \times 40 = 20,000$$

$$\text{records} = \boxed{20,000} \quad \{\text{records}\}$$

Therefore, **20,000 records** can be extracted before the attack is blocked.

Step 2: Calculate percentage of total data compromised

$$\text{Total records} = 50,000$$

$$\text{Compromised records} = 20,000$$

$$\text{Percentage compromised} = \frac{20,000}{50,000} \times 100 \quad \{\text{Percentage compromised}\} = \frac{20,000}{50,000} \times 100 = 40\% = \boxed{40\%}$$

Therefore, **40% of the entire database** could be compromised.

Step 3: Calculate sensitive records exposed

Sensitive records represent **30%** of the database.

$$50,000 \times 30\% = 15,000 \quad 50,000 \times 30\% = 15,000$$

So, there are **15,000 sensitive records** in total.

Assuming the extracted records have the same 30% sensitive-data proportion:

$$20,000 \times 30\% \quad 20,000 \times 30\% = 20,000 \times 0.30 = 20,000 \times 0.30 = 6,000 = \boxed{6,000}$$

Therefore, approximately **6,000 sensitive records** could be exposed.

Step 4: Evaluate the severity of the breach

The breach is **high severity** because:

- **20,000 records** can be extracted.
- This represents **40% of the entire database**.
- Approximately **6,000 sensitive records** may be exposed.
- A SQL injection vulnerability can potentially allow unauthorized access to large amounts of database information.
- Sensitive customer information could result in financial, privacy, legal, and reputational consequences.

Although the application firewall detects and blocks the attack after 40 seconds, the attacker can still extract a substantial amount of data before being stopped.

Step 5: Is the existing detection mechanism sufficient?

No. The detection mechanism is helpful but **not sufficient by itself**.

Blocking the attack after 40 seconds still allows:

20,000 records\boxed{20,000\text{ records}}

to be extracted.

A stronger security approach should include:

- Parameterized queries/prepared statements
- Input validation and sanitization
- Secure database access controls
- Least-privilege database accounts
- Web Application Firewall (WAF) rules
- Real-time SQL injection detection
- Database activity monitoring
- Regular vulnerability and penetration testing
- Logging and alerting for suspicious queries

Final Answer

The SQL injection attack can extract **20,000 records** before being blocked because the extraction rate is 500 records per second for 40 seconds. This represents **40% of the total 50,000 records**. Since 30% of the database is sensitive, approximately **6,000 sensitive records** could be exposed. The breach should therefore be considered **high severity** because a large proportion of the database and thousands of sensitive records may be compromised. Although the application firewall

provides an important defensive layer, detecting the attack only after 40 seconds is not sufficient to protect critical data. Preventive controls such as parameterized queries, input validation, least-privilege database access, and continuous database monitoring should also be implemented.
